

Scaling Vulnerability Disclosure for Open Source

A federated, maintainer-first path forward



OpenSSF

OPEN SOURCE SECURITY FOUNDATION

Who is this?



Kris Borchers - Technical Project Manager, OpenSSF



Long history in open source, former ED of jQuery and JS Foundations



Started InnerSource program in Azure at Microsoft



Started OSPO at GM Financial

Open Source Security Foundation (OpenSSF)



Mission: Make it easier to sustainably secure the development, maintenance, release, and consumption of open source software (OSS).



Fostering collaboration within and beyond the OpenSSF



Establishing best practices

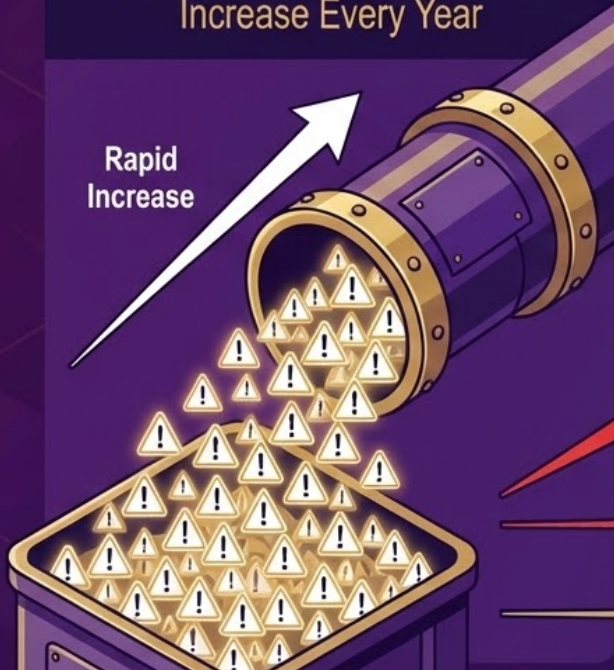


Developing innovative solutions

Why This Matters Now: The Growing Gap

Reported Vulnerabilities
Increase Every Year

Rapid
Increase



Upstream Maintainer Capacity
Has Not Grown at the Same Rate

Slow & Limited

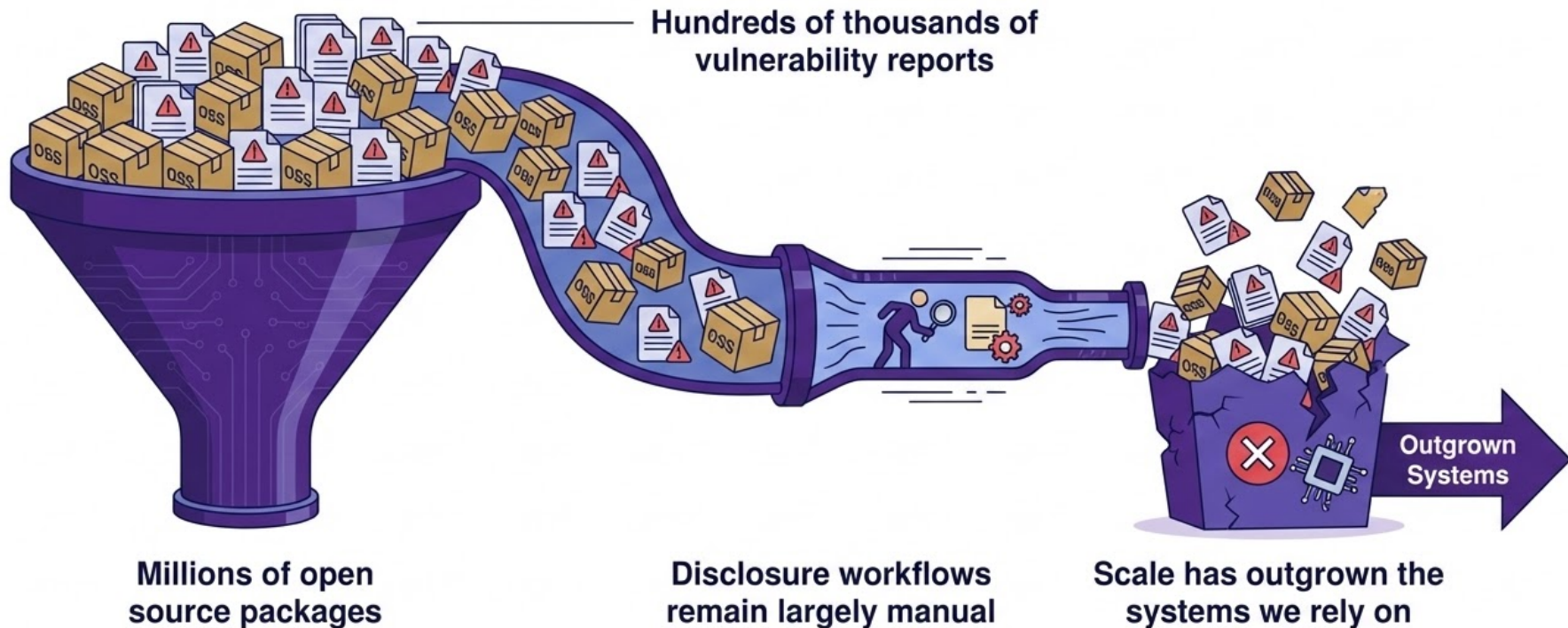


Vulnerability Disclosure Systems
Have Not Kept Pace

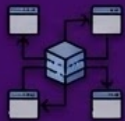
Outpaced & Overwhelmed



The Mismatch We've Created



What Today's Systems Were Built For



- Smaller software ecosystems



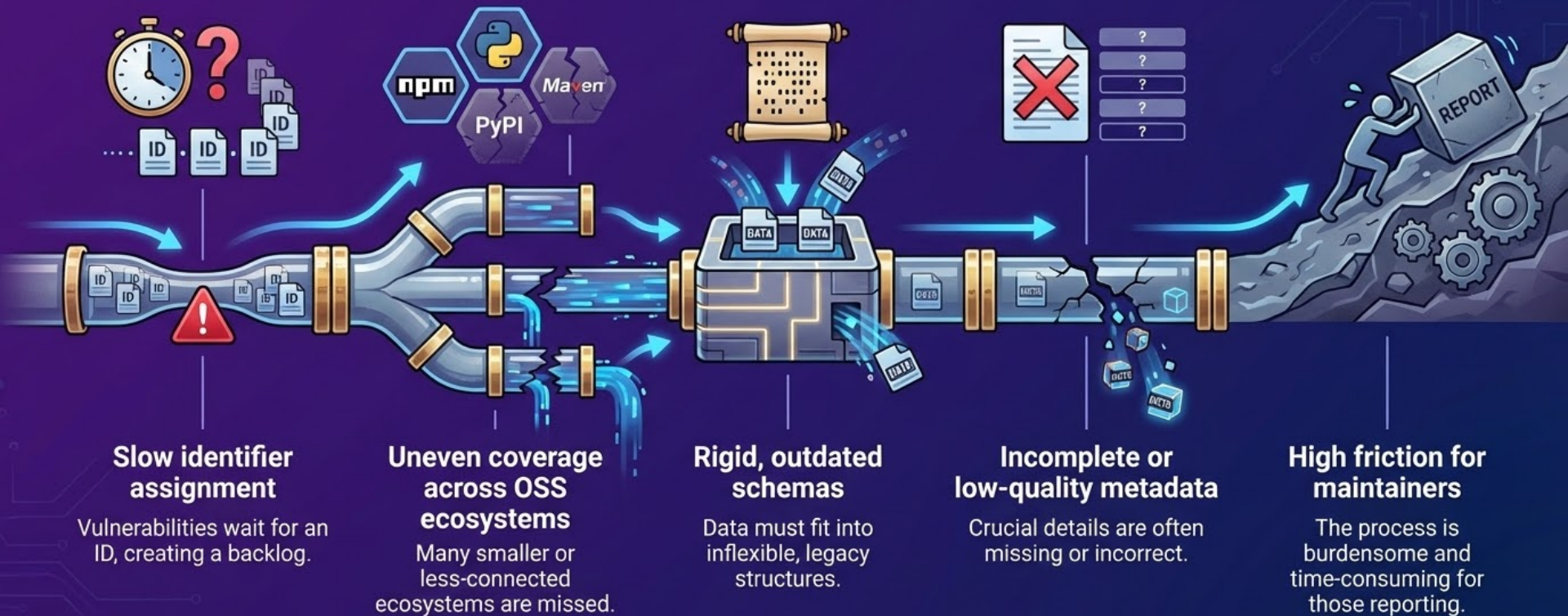
- Slower discovery and disclosure cycles



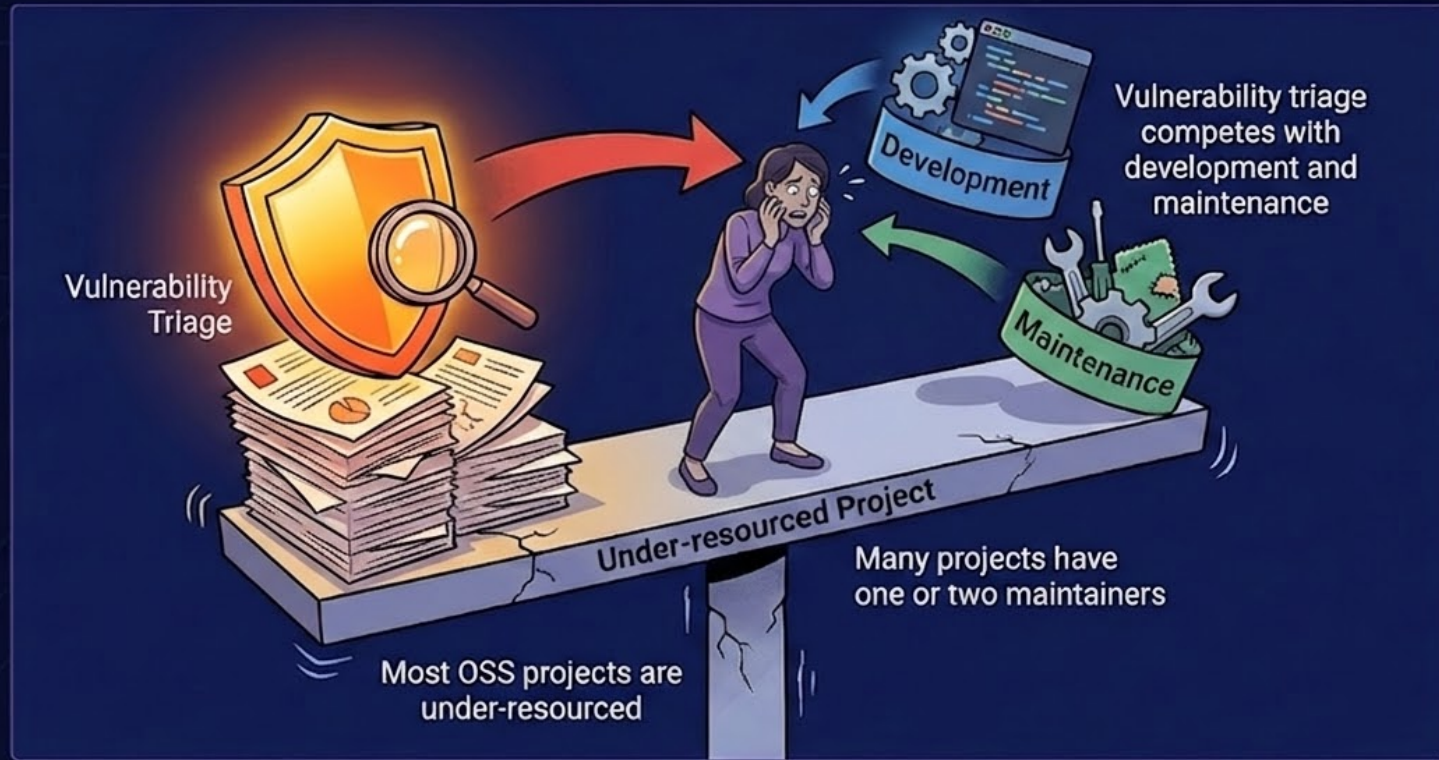
- Vendor-centric software models

They worked well — for a different era

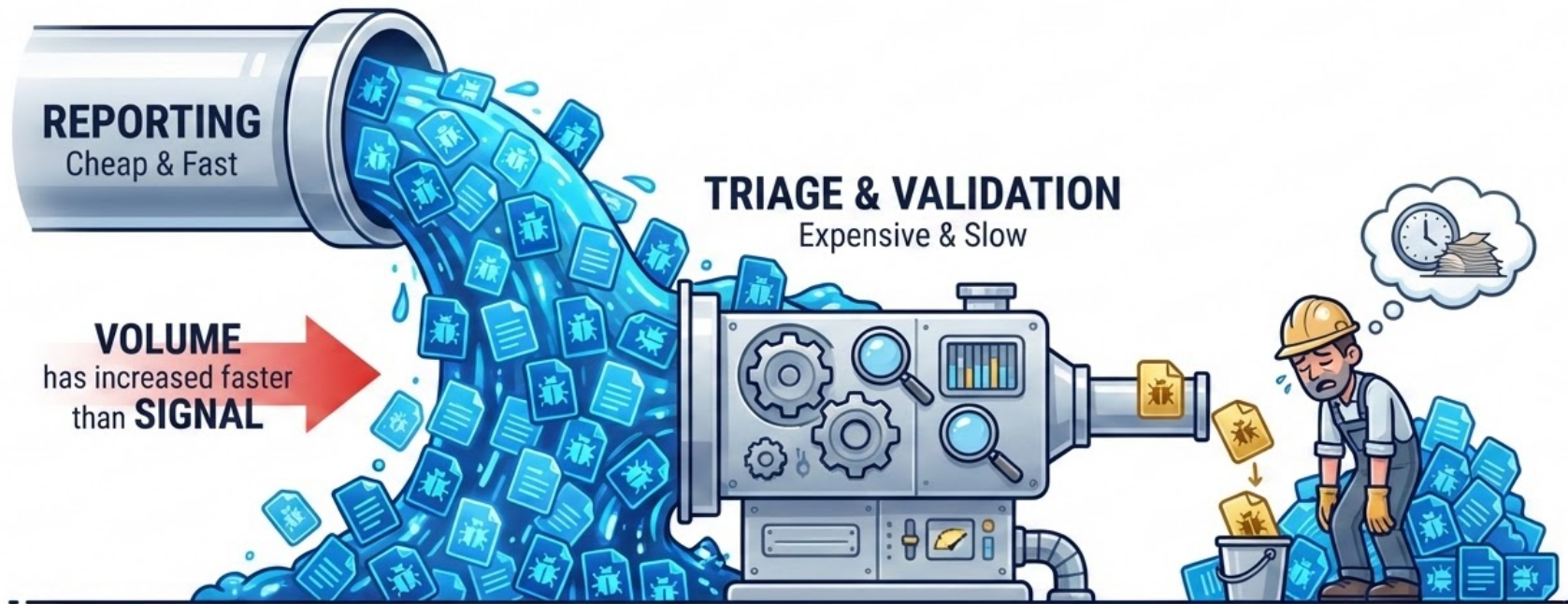
Where the Current Model Breaks Down



The Maintainer Reality

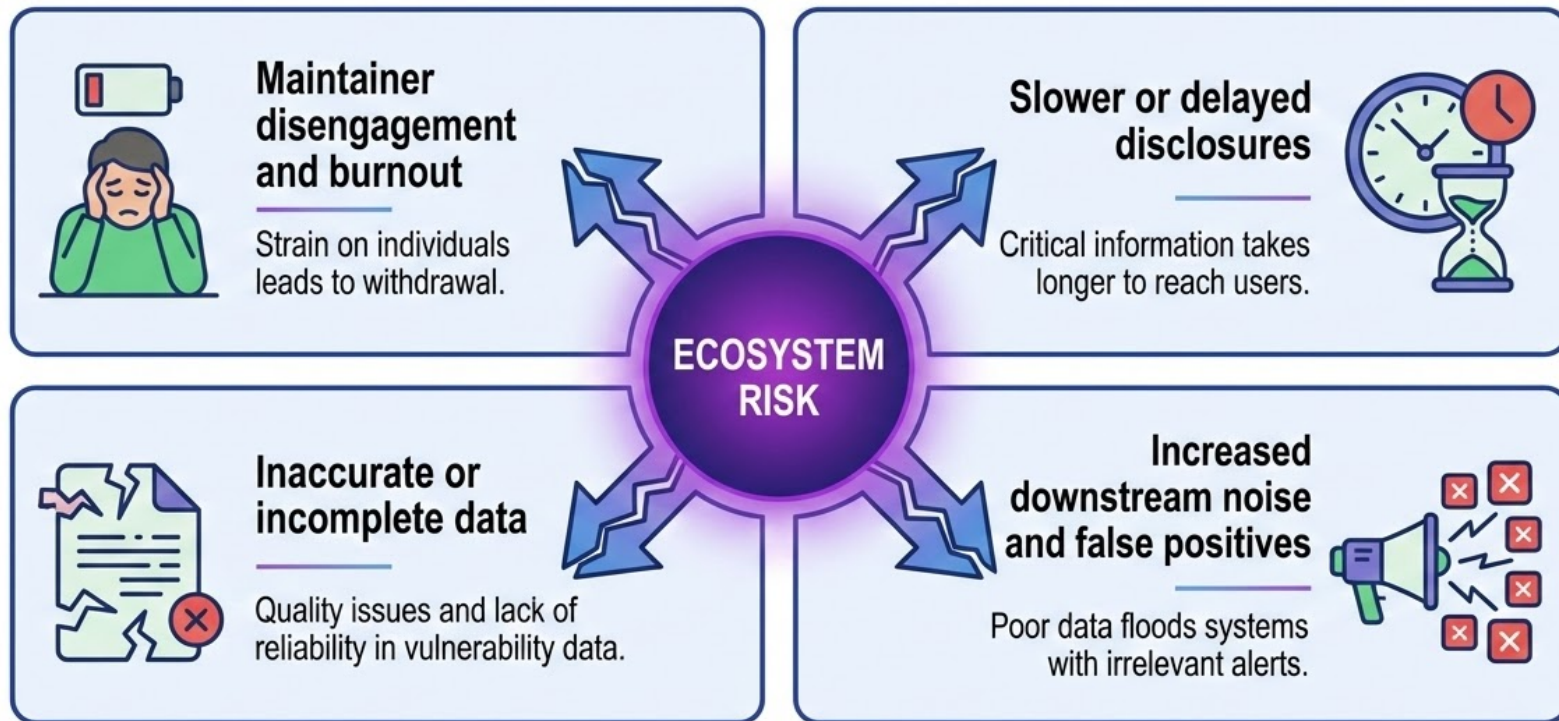


AI Changed the Math



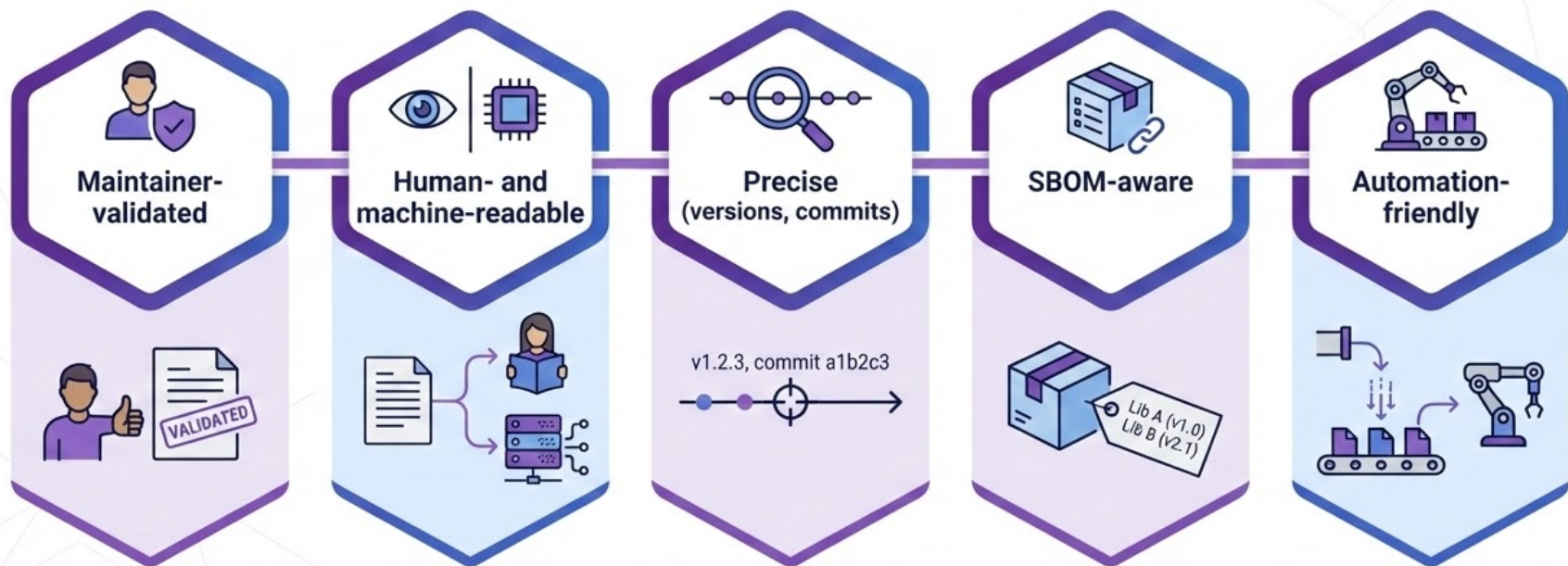
“When reporting is cheap but triage is expensive, maintainers lose.”

Resulting Ecosystem Risk

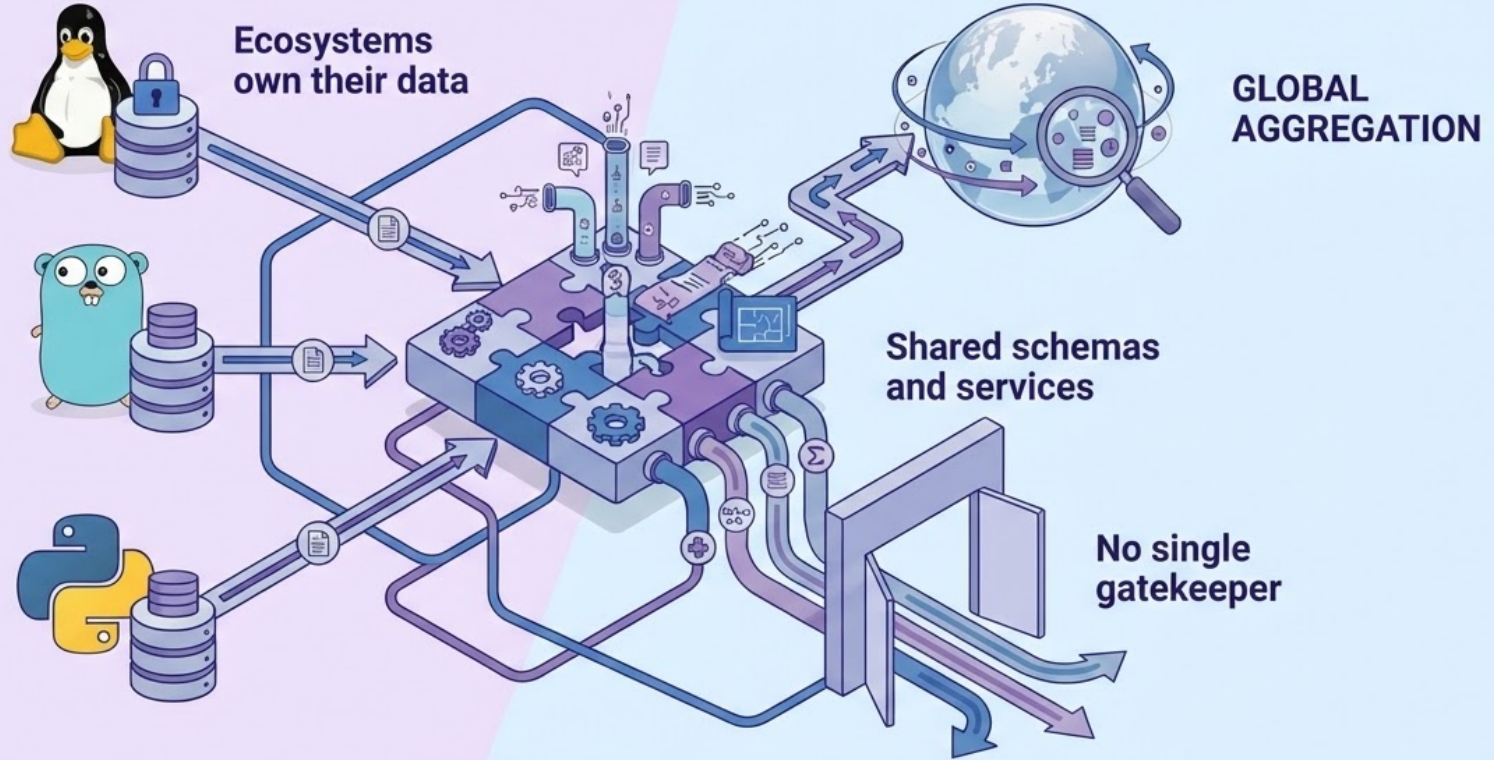


What Good Looks Like

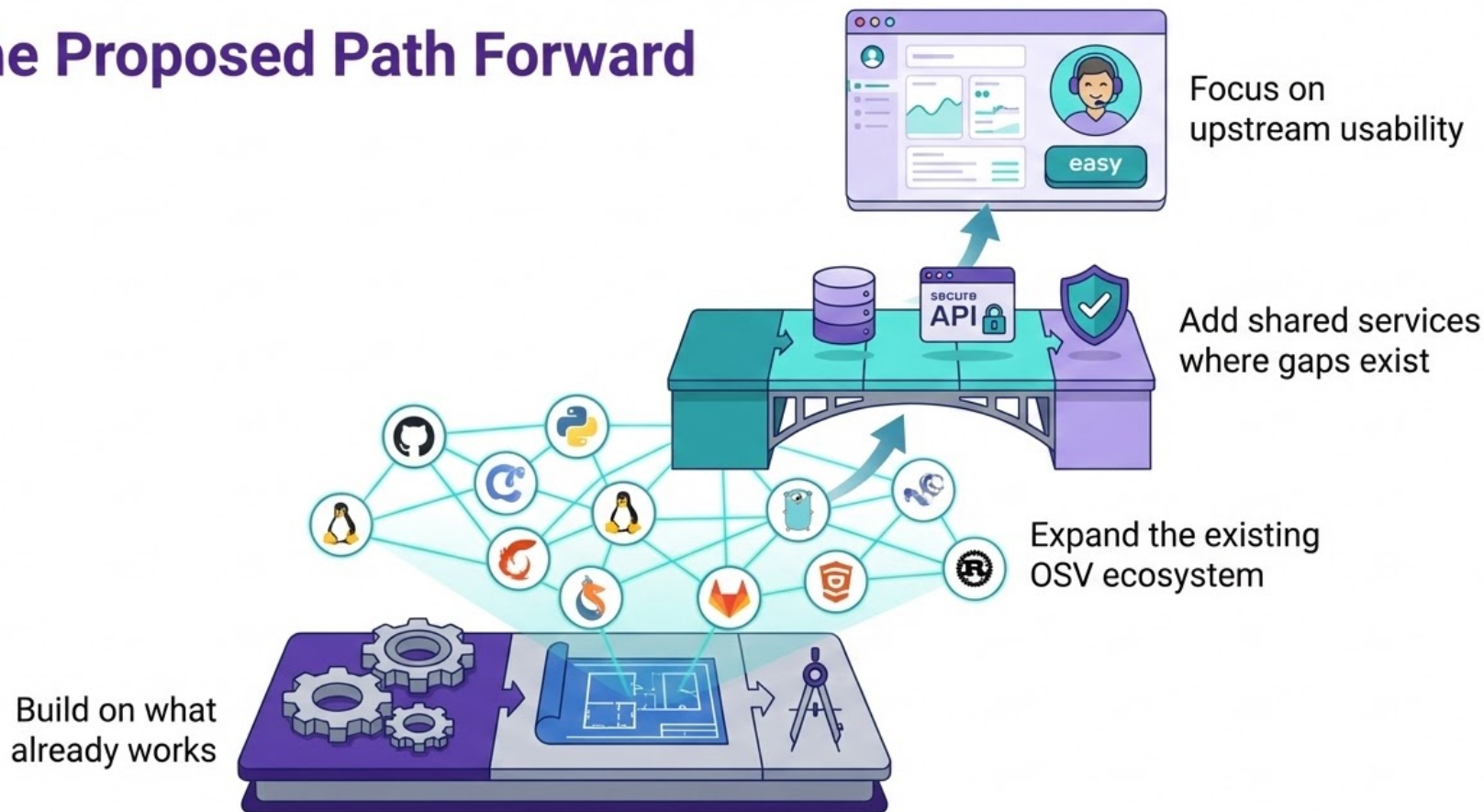
Modern vulnerability data should be:



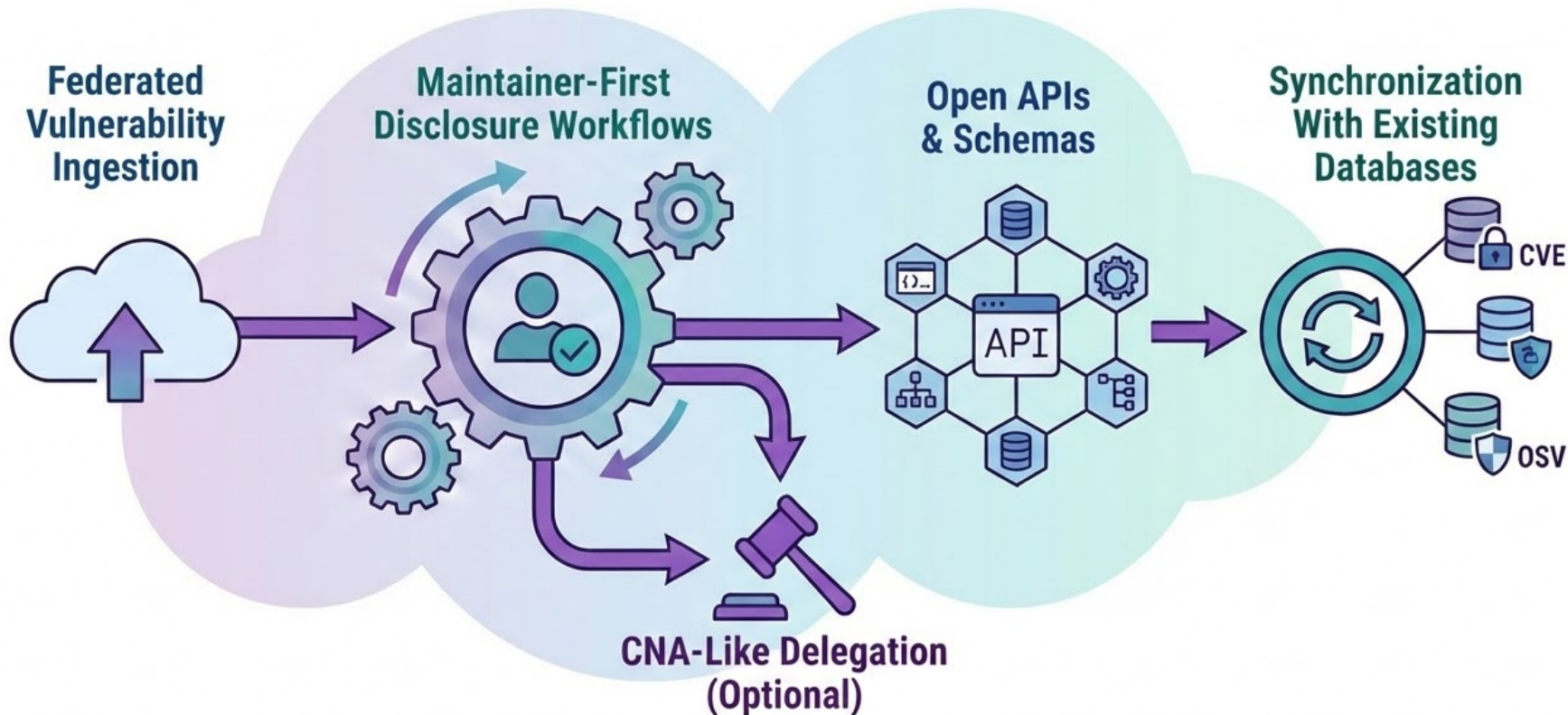
A Different Approach: Federation



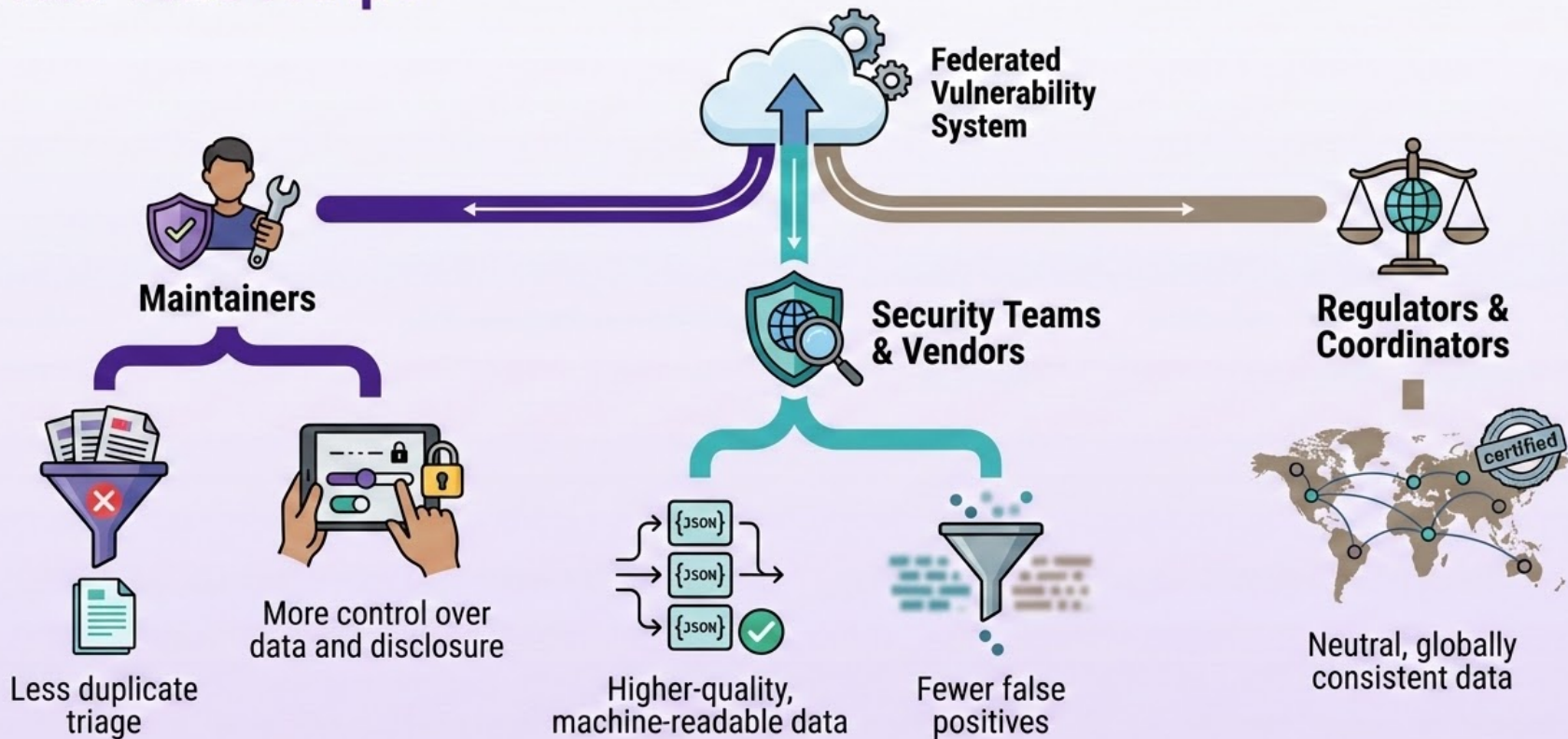
The Proposed Path Forward



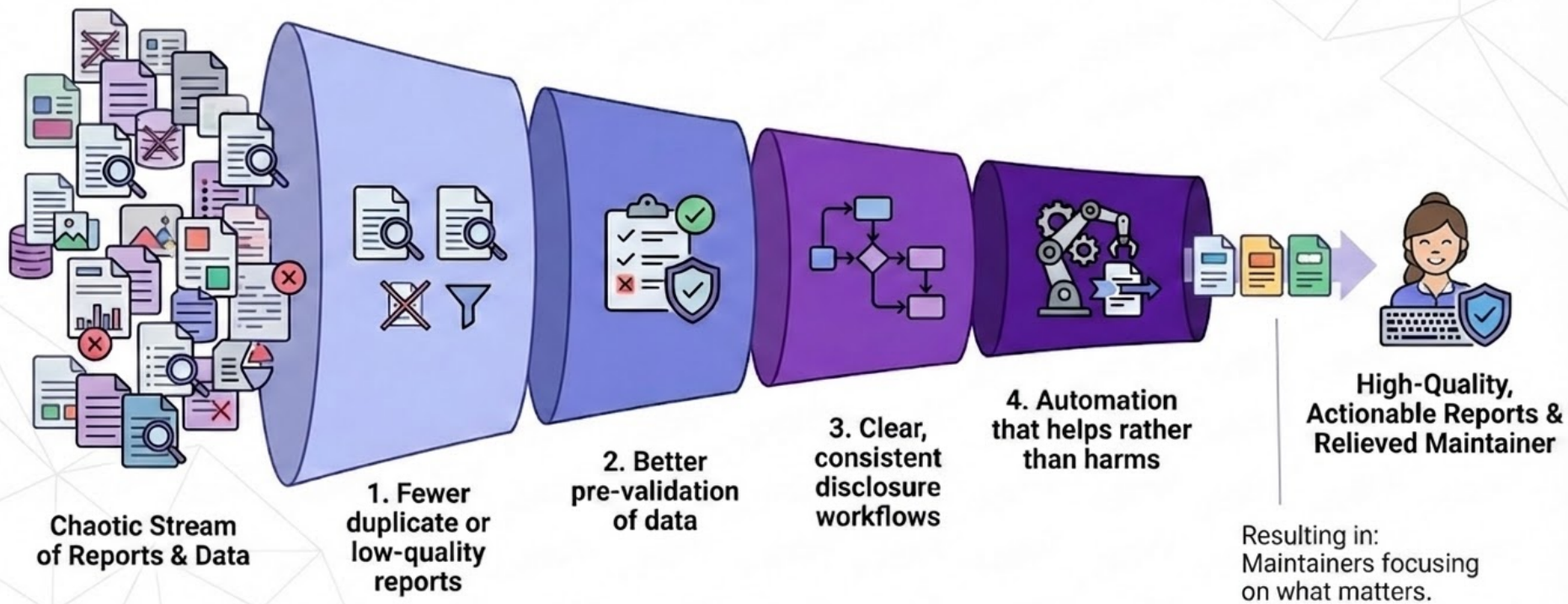
Core Capabilities



Who This Helps



Reducing Maintainer Burnout



What This Is Not



Not “replacing CVE”



Not a single new gatekeeper



Not forcing maintainers into
bureaucracy

Why Neutral Governance Matters

Global trust and credibility

Global trust and credibility builds confidence and reliability across all participants.



Long-term sustainability

Long-term sustainability ensures enduring support and growth for the ecosystem.



Neutral Governance



Vendor- and government-neutral stewardship

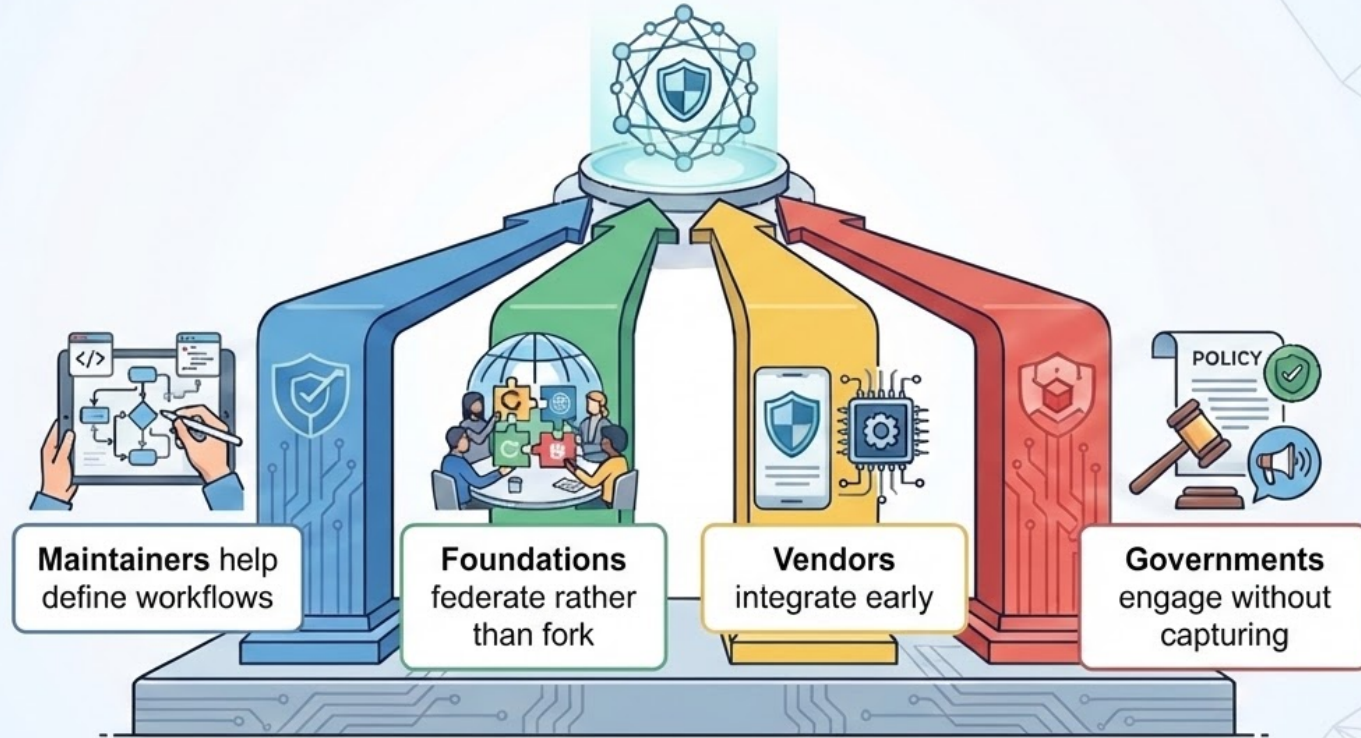
Vendor- and government-neutral stewardship guarantees impartial and equitable management.



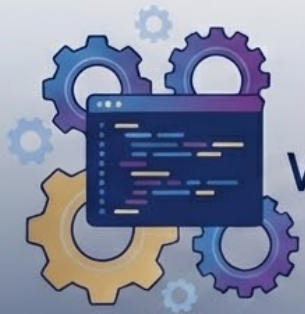
Open participation across ecosystems

Open participation across ecosystems fosters collaboration and inclusivity for everyone.

Building This Together



Closing



“If we want better vulnerability data,
we have to design systems developers
actually want to use.”



Call to Action



Thank You



kborchers@linuxfoundation.org



<https://www.linkedin.com/in/kborchers/>



<https://github.com/kborchers>



[#wg-vulnerability-disclosures](#)



OpenSSF
OPEN SOURCE SECURITY FOUNDATION

*Infographics and background images
generated by Gemini*



Legal Notice

Copyright © [Open Source Security Foundation](#)®, [The Linux Foundation](#)®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the [OpenSSF Charter](#), this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <<https://creativecommons.org/licenses/by/4.0/>>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.